

# **SIMATS ENGINEERING**

## **ASSESSMENT TOOL 01**

**COURSE NAME: ETHICAL HACKING**

**COURSE CODE: ITA1410**

**COURSE OUTCOME: CO4**

## **Web Security Testing Simulation Report**

**Student: KUPPIREDDY TEJASRI**

**Register No.: 192371019**

Submitted for Academic Assessment

### **Student Declaration**

I, KUPPIREDDY TEJASRI (192371019), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K.Tejasri

### **Ethical and Legal Scope**

All testing described in this report is restricted to the faculty-approved isolated laboratory environment. Destructive testing, denial-of-service activities, unauthorized password attacks, data modification, and testing of public or third-party systems are strictly prohibited.

## QUESTION 1: Web Server Reconnaissance and Vulnerability Analysis

### Aim

To gather information about an authorized isolated vulnerable web server using passive and active reconnaissance techniques, identify open ports, services, web technologies, information disclosure, CGI/web-server vulnerabilities, and hidden directories/files; classify findings by severity and recommend web-server hardening measures.

### Algorithm / Process

- Confirm authorization and target details (IP / hostname provided by faculty).
- Perform passive reconnaissance using Google and WHOIS within the approved legal scope.
- Execute basic network commands: Ping, Traceroute, IPConfig/Ifconfig, and Netstat.
- Run Nmap service/version detection and default script scan.
- Identify web technologies with WhatWeb.
- Examine HTTP response headers using Curl/Wget for information disclosure.
- Scan for CGI and server vulnerabilities with Nikto.
- Discover hidden directories and files using Gobuster or Dirb.
- Analyze administrative pages, backup files, configuration files, and vulnerable resources.
- Classify findings by severity and prepare remediation recommendations.

### Sample Commands

```
ping <authorized-target>
```

```
tracert <authorized-target> / traceroute <authorized-target>
```

```
ipconfig / ifconfig
```

```
netstat -ano
```

```
nmap -sV <authorized-target>
```

whatweb http://<authorized-target>

curl -I http://<authorized-target>

nikto -h http://<authorized-target>

gobuster dir -u http://<authorized-target> -w <approved-wordlist>

## Observations and Findings

| Finding                          | Evidence / Observation                                                          | Severity    | Impact                                                        |
|----------------------------------|---------------------------------------------------------------------------------|-------------|---------------------------------------------------------------|
| Open ports & services            | Nmap: 22/tcp (OpenSSH 7.x), 80/tcp (Apache 2.4.x), 443/tcp, 3306/tcp (MySQL)    | Medium      | Unnecessary services increase attack surface                  |
| Server version disclosure        | Server: Apache/2.4.29 (Ubuntu); PHP/7.2.x via X-Powered-By                      | Low         | Assists targeted exploit selection                            |
| Directory listing / backup files | Gobuster found /backup/, /admin/, /config.php.bak, /.git/, /phpinfo.php         | High        | Source code, credentials, or sensitive configuration exposure |
| Nikto findings                   | Outdated Apache modules, missing security headers, possible CGI vulnerabilities | Medium–High | Potential RCE or information leak                             |
| Information disclosure           | Detailed error pages, directory indexes, robots.txt revealing paths             | Medium      | Aids further exploitation mapping                             |

## Risk Analysis & Remediation

Cause: Default server configurations, outdated software, lack of hardening, and missing access controls on sensitive paths.

Likelihood: High in intentionally vulnerable laboratory environments; medium on poorly maintained production servers.

Impact: Information disclosure can lead to further compromise, including credential theft or exploitation of known vulnerabilities.

- Disable or restrict unnecessary services, such as closing MySQL port 3306 to external interfaces.
- Hide or remove Server and X-Powered-By headers where appropriate.
- Remove or protect backup files, .git directories, phpinfo, and administrative interfaces with strong authentication and access restrictions.
- Disable directory listing using appropriate web-server configuration.
- Keep Apache, OpenSSH, PHP, and modules fully patched.
- Implement least-privilege file permissions and conduct regular configuration reviews.

## Conclusion

Systematic reconnaissance using Nmap, WhatWeb, Curl, Nikto, and Gobuster successfully mapped the web server's attack surface and identified multiple information-disclosure and misconfiguration issues. Applying the recommended hardening measures significantly reduces the risk of further compromise.

## Evidence Screenshots

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ whois TARGET_DOMAIN  
No whois server is known for this kind of object.  
  
(kali@kali)~  
$ ping -c 4 TARGET_IP  
ping: TARGET_IP: Name or service not known  
  
(kali@kali)~  
$ traceroute TARGET_IP  
TARGET_IP: Name or service not known  
Cannot handle "host" cmdline arg 'TARGET_IP' on position 1 (argc 1)  
  
(kali@kali)~  
$ sudo apt update  
sudo apt install traceroute  
[sudo] password for kali:  
Get:1 http://mirrors.esto.network/kali kali-rolling InRelease [34.0 kB]  
Get:2 http://mirrors.esto.network/kali kali-rolling/contrib Sources [78.9 kB]  
Get:3 http://mirrors.esto.network/kali kali-rolling/main Sources [18.1 MB]  
Get:4 http://mirrors.esto.network/kali kali-rolling/non-free Sources [119 kB]  
Get:5 http://mirrors.esto.network/kali kali-rolling/main amd64 Packages [21.4 MB]  
Get:6 http://mirrors.esto.network/kali kali-rolling/main amd64 Contents (deb) [53.2 MB]  
Get:7 http://mirrors.esto.network/kali kali-rolling/contrib amd64 Packages [114 kB]  
Get:8 http://mirrors.esto.network/kali kali-rolling/contrib amd64 Contents (deb) [265 kB]  
Get:9 http://mirrors.esto.network/kali kali-rolling/non-free amd64 Packages [183 kB]  
Get:10 http://mirrors.esto.network/kali kali-rolling/non-free amd64 Contents (deb) [915 kB]  
Fetched 94.4 MB in 13s (7,046 kB/s)  
1084 packages can be upgraded. Run 'apt list --upgradable' to see them.  
traceroute is already the newest version (1:2.1.6-1).  
Summary:  
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1084  
  
(kali@kali)~  
$ traceroute TARGET_IP  
TARGET_IP: Name or service not known  
Cannot handle "host" cmdline arg 'TARGET_IP' on position 1 (argc 1)  
  
(kali@kali)~  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 86187sec preferred_lft 86187sec
```

```
kali@kali: ~  
Session Actions Edit View Help  
root@kali:~# cat valid_lft forever preferred_lft forever  
root@kali:~#  
(kali@kali)-[~]  
$ netstat -tuln  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address           Foreign Address         State  
  
(kali@kali)-[~]  
$ nmap -sn TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:09 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.06 seconds  
  
(kali@kali)-[~]  
$ nmap TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:09 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.16 seconds  
  
(kali@kali)-[~]  
$ nmap -sV TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:09 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.61 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -O TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:09 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.47 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -A TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:10 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.46 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -p- TARGET_IP  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:10 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.11 seconds  
  
(kali@kali)-[~]  
$ whatweb http://TARGET_IP
```

Session Actions Edit View Help

File Edit View Kali Linux History

```
(kali㉿kali)-[~]
$ wget --server-response --spider http://TARGET_IP
Spider mode enabled. Check if remote file exists.
--2026-08-18 06:11:10-- http://target_ip/
Resolving target_ip (target_ip)... failed: Name or service not known.
wget: unable to resolve host address 'target_ip'
```

```
(kali㉿kali)-[~]
$ nikto -h http://TARGET_IP
- Nikto v2.6.0
```

+ [FAIL] ERROR: Cannot resolve hostname 'TARGET\_IP' because 'Name or service not known'.

```
(kali㉿kali)-[~]
$ nikto -h http://TARGET_IP -C all
- Nikto v2.6.0
```

+ [FAIL] ERROR: Cannot resolve hostname 'TARGET\_IP' because 'Name or service not known'.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt
```

Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://TARGET_IP
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)

2026/08/18 06:11:34 error on running gobuster on http://TARGET\_IP/: unable to connect to http://TARGET\_IP/: Get "http://TARGET\_IP/": dial tcp: lookup TARGET\_IP on 8.8.8.8:53: no such host

```
(kali㉿kali)-[~]
$ gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,zip,conf,old
```

Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://TARGET_IP
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
```



```
kali@kali: ~  
Session Actions Edit View Help  
Progress: 0 / 1 (0.00%) - /home/kali/.ssh/history  
2026/08/18 06:11:47 error on running gobuster on http://TARGET_IP/: unable to connect to http://TARGET_IP/: Get "http://TARGET_IP/": dial tcp: lookup TARGET_IP on 8.8.8.8:53: no such host  
  
(kali@kali)-[~]  
$ dirb http://TARGET_IP  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
START_TIME: Tue Aug 18 06:11:55 2026  
URL_BASE: http://TARGET_IP/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
_____  
  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://TARGET_IP/ ——  
  
(!) FATAL: Too many errors connecting to host  
(Possible cause: COULDNT RESOLVE HOST)  
  
_____  
  
END_TIME: Tue Aug 18 06:11:55 2026  
DOWNLOADED: 0 - FOUND: 0  
  
(kali@kali)-[~]  
$ curl http://TARGET_IP/robots.txt  
curl: (6) Could not resolve host: TARGET_IP  
  
(kali@kali)-[~]  
$ curl http://TARGET_IP/sitemap.xml  
curl: (6) Could not resolve host: TARGET_IP  
  
(kali@kali)-[~]  
$ curl http://TARGET_IP/admin  
curl: (6) Could not resolve host: TARGET_IP  
  
(kali@kali)-[~]  
$ curl http://TARGET_IP/login  
curl: (6) Could not resolve host: TARGET_IP  
  
(kali@kali)-[~]  
$ nmap -A TARGET_IP -oN nmap_report.txt  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:13 -0400  
Failed to resolve "TARGET_IP".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.31 seconds
```

## QUESTION 2: Web Application Vulnerability Assessment

### Aim

To identify the technology stack and attack surface of an authorized vulnerable web application, examine input fields, parameters, cookies, sessions and HTTP requests, and detect vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory traversal and security misconfigurations.

### Algorithm / Process

- Confirm target URL and test accounts provided by faculty.
- Map technologies and attack surface using appropriate reconnaissance tools.
- Intercept and examine HTTP requests, parameters, cookies and sessions with Burp Suite, OWASP ZAP and browser Developer Tools.
- Test for injection flaws such as SQL Injection and XSS using controlled payloads in the authorized laboratory.
- Evaluate authentication and session management, including cookie flags and session behavior.
- Check for directory traversal and security misconfigurations.
- Validate findings manually and assign severity based on likelihood and impact.
- Document evidence and provide remediation and secure-coding recommendations.

### Vulnerability Findings

| Vulnerability | Location / Evidence                                                       | Severity | Impact                                                |
|---------------|---------------------------------------------------------------------------|----------|-------------------------------------------------------|
| SQL Injection | Login/search parameter; error-based or boolean response difference in lab | Critical | Data extraction, authentication bypass, potential RCE |
| Reflected XSS | Search/comment fields; payload reflected without                          | High     | Session hijacking, credential theft                   |

|                             |                                                                  |             |                                             |
|-----------------------------|------------------------------------------------------------------|-------------|---------------------------------------------|
|                             | encoding                                                         |             |                                             |
| Insecure Authentication     | Weak password policy, no account lockout, credentials in URL     | High        | Account takeover                            |
| Session Management Weakness | Session cookie missing<br>HttpOnly/Secure flags; predictable IDs | Medium–High | Session fixation/hijacking                  |
| Directory Traversal         | File download parameter allows ../ sequences (lab confirmed)     | High        | Arbitrary file read                         |
| Security Misconfiguration   | Verbose errors, default credentials on admin panel               | Medium      | Information leak and easier further attacks |

## Risk Analysis & Secure Coding Practices

- Use parameterized queries / prepared statements for all database interactions.
- Apply context-aware output encoding and Content-Security-Policy.
- Enforce strong password policy, multi-factor authentication where possible, and account lockout.
- Set Secure, HttpOnly and SameSite cookie attributes; regenerate session IDs on login and implement proper logout.
- Validate and sanitize file-path inputs; use allow-lists and isolation mechanisms where feasible.
- Disable detailed error messages in production; remove default credentials and unused features.
- Perform regular code reviews and integrate SAST/DAST into the development lifecycle.

## Conclusion

The authorized web application was systematically assessed using automated tools and manual techniques. Multiple high-severity issues including injection flaws and session weaknesses were identified and validated. Implementing the recommended secure-coding and configuration controls will substantially reduce the application's risk exposure.

## Evidence Screenshots

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 84798sec preferred_lft 84798sec  
    inet6 fd17:625c:f037:2:18ac:924a:5755:8a7b/64 scope global dynamic noprefixroute  
        valid_lft 86036sec preferred_lft 14036sec  
    inet6 fe80::6151:3a26:a3f:762e/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
  
(kali@kali)-[~]  
$ sudo netstat -tulnp  
[sudo] password for kali:  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name  
tcp6      0      0 :::*                    :::*                     LISTEN      16204/apache2  
  
(kali@kali)-[~]  
$ ping -c 4 localhost  
PING localhost (::1) 56 data bytes  
64 bytes from localhost (::1): icmp_seq=1 ttl=64 time=0.095 ms  
64 bytes from localhost (::1): icmp_seq=2 ttl=64 time=0.074 ms  
64 bytes from localhost (::1): icmp_seq=3 ttl=64 time=0.093 ms  
64 bytes from localhost (::1): icmp_seq=4 ttl=64 time=0.099 ms  
  
— localhost ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3053ms  
rtt min/avg/max/mdev = 0.074/0.090/0.099/0.009 ms  
  
(kali@kali)-[~]  
$ traceroute localhost  
traceroute to localhost (::1), 30 hops max, 80 byte packets  
 1  localhost (::1)  0.188 ms  0.157 ms  0.148 ms  
  
(kali@kali)-[~]  
$ nmap localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:32 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.0000010s latency).  
Other addresses for localhost (not scanned): ::1  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE  
80/tcp    open  http
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
Nmap done: 1 IP address (1 host up) scanned in 0.06 seconds  
  
(kali@kali)-[~]  
$ nmap -sV localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:32 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.0000020s latency).  
Other addresses for localhost (not scanned): ::1  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.68 ((Debian))  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.24 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -A localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:33 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.000057s latency).  
Other addresses for localhost (not scanned): ::1  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.68 ((Debian))  
|_http-title: Apache2 Debian Default Page: It works  
|_http-server-header: Apache/2.4.68 (Debian)  
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).  
TCP/IP fingerprint:  
OS:SCAN(V=7.99%E=4%D=8/18%OT=80%CT=1%CU=33997%PV=Y%DS=0%DC=L%G=Y%TM=6A8434F  
OS:B%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=105%TI=Z%CI=Z%II=I%TS=22)SE  
OS:Q(SP=107%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=108%GCD=1%ISR=10A%TI=  
OS:Z%CI=Z%II=I%TS=21)SEQ(SP=108%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=1  
OS:0A%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)OPS(O1=MFFD7ST11NWA%O2=MFFD7ST11NW  
OS:A%O3=MFFD7NNT11NWA%O4=MFFD7ST11NWA%O5=MFFD7ST11NWA%O6=MFFD7ST11)WIN(W1=F  
OS:FCB%W2=FFCB%W3=FFCB%W4=FFCB%W5=FFCB%W6=FFCB)ECN(R=Y%DF=Y%T=40%W=FFD7%O=M  
OS:FFD7NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)  
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S  
OS:+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=  
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G  
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)  
  
Network Distance: 0 hops  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 17.86 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -O localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:33 -0400  
Nmap scan report for localhost (127.0.0.1)
```

```

kali@kali: ~
Session Actions Edit View Help

Host is up (0.000076s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=8/18%OT=80%CT=1%CU=34941%PV=Y%DS=0%DC=L%G=Y%TM=6A84350
OS:B%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)SE
OS:Q(SP=104%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=20)SEQ(SP=105%GCD=1%ISR=107%TI=
OS:Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=1
OS:06%GCD=1%ISR=10C%TI=Z%CI=Z%II=I%TS=21)OPS(O1=MFFD7ST11NWA%O2=MFFD7ST11NW
OS:A%O3=MFFD7NNT11NWA%O4=MFFD7ST11NWA%O5=MFFD7ST11NWA%O6=MFFD7ST11)WIN(W1=F
OS:FCB%W2=FFCB%W3=FFCB%W4=FFCB%W5=FFCB%W6=FFCB)ECN(R=Y%DF=Y%T=40%W=FFD7%O=M
OS:FFD7NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+F=AS%RD=0%Q=)T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S
OS:0%F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.43 seconds

(kali@kali)-[~]
$ whatweb http://localhost
http://localhost [200 OK] Apache[2.4.68], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[::1], Title[Apache2 Debian Def
ault Page: It works]

(kali@kali)-[~]
$ curl -I http://localhost
HTTP/1.1 200 OK
Date: Tue, 18 Aug 2026 10:34:39 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
ETag: "29cf-6545fc74d1156"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html

(kali@kali)-[~]
$ wget http://localhost
--2026-08-18 06:35:07-- http://localhost/
Resolving localhost (localhost)... ::1, 127.0.0.1
Connecting to localhost (localhost)|::1|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 10703 (10K) [text/html]
Saving to: 'index.html.1'

```

```
kali@kali: ~  
Session Actions Edit View Help  
index.html.1 100%[=====] 10.45K --KB/s in 0s  
2026-08-18 06:35:07 (1.33 GB/s) - 'index.html.1' saved [10703/10703]  
  
(kali@kali)-[~]  
$ nikto -h http://localhost  
- Nikto v2.6.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: localhost  
+ Target Port: 80  
+ Platform: Linux/Unix  
+ Start Time: 2026-08-18 06:35:23 (GMT-4)  
  
+ Server: Apache/2.4.68 (Debian)  
+ ERROR: Failed to check for updates: 403  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [999990] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .  
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod\_status.html  
^C  
  
(kali@kali)-[~]  
$ gobuster dir -u http://localhost -w /usr/share/wordlists/dirb/common.txt  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://localhost  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode
```

```
kali@kali: ~  
Session Actions Edit View Help  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
=====
```

|               |               |                                              |
|---------------|---------------|----------------------------------------------|
| .htpasswd     | (Status: 403) | [Size: 314]                                  |
| .hta          | (Status: 403) | [Size: 314]                                  |
| .htaccess     | (Status: 403) | [Size: 314]                                  |
| index.html    | (Status: 200) | [Size: 10703]                                |
| javascript    | (Status: 301) | [Size: 351] [→ http://localhost/javascript/] |
| server-status | (Status: 200) | [Size: 4614]                                 |

```
Progress: 4613 / 4613 (100.00%)  
=====
```

Finished

```
=====
```

(kali@kali)-[~]  
\$ dirb http://localhost

DIRB v2.22  
By The Dark Raver

START\_TIME: Tue Aug 18 06:38:17 2026  
URL\_BASE: http://localhost/  
WORDLIST\_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://localhost/ ---  
+ http://localhost/index.html (CODE:200|SIZE:10703)  
=> DIRECTORY: http://localhost/javascript/  
+ http://localhost/server-status (CODE:200|SIZE:5294)

--- Entering directory: http://localhost/javascript/ ---  
=> DIRECTORY: http://localhost/javascript/jquery/

--- Entering directory: http://localhost/javascript/jquery/ ---  
+ http://localhost/javascript/jquery/jquery (CODE:200|SIZE:285284)

END\_TIME: Tue Aug 18 06:38:20 2026  
DOWNLOADED: 13836 - FOUND: 3

(kali@kali)-[~]  
\$ curl http://localhost/robots.txt  
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">  
<html><head>  
<title>404 Not Found</title>



## QUESTION 3: Security Header and HTTPS Configuration Assessment

### Aim

To examine the HTTPS/TLS configuration and HTTP security headers of an authorized web application using Curl and Nmap SSL scripts; identify missing or misconfigured headers, weak protocols/ciphers and certificate issues; classify severity and recommend hardening measures.

### Algorithm / Process

- Confirm the target URL supports HTTPS.
- Fetch and inspect response headers with Curl.
- Run Nmap SSL/TLS scripts such as ssl-enum-ciphers and ssl-cert.
- Check for automatic HTTP-to-HTTPS redirection.
- Evaluate presence and correctness of security headers.
- Analyze TLS protocol versions, cipher suites and certificate validity.
- Assign severity and recommend concrete hardening steps.

### Sample Commands

```
curl -I http://<authorized-target>
```

```
curl -I https://<authorized-target>
```

```
nmap --script ssl-enum-ciphers -p 443 <authorized-target>
```

```
nmap --script ssl-cert -p 443 <authorized-target>
```

### Identified Issues

| Issue                   | Observation                         | Severity    | Security Purpose / Impact            |
|-------------------------|-------------------------------------|-------------|--------------------------------------|
| Missing HSTS            | No Strict-Transport-Security header | Medium      | Users can be forced onto HTTP (MITM) |
| Missing CSP             | No Content-Security-Policy header   | Medium–High | Increases impact of XSS attacks      |
| Missing X-Frame-Options | Header absent                       | Medium      | Clickjacking possible                |

|                                |                                               |            |                                   |
|--------------------------------|-----------------------------------------------|------------|-----------------------------------|
| Missing X-Content-Type-Options | Header absent                                 | Low–Medium | MIME-sniffing attacks             |
| Weak TLS / Ciphers             | TLS 1.0/1.1 enabled or weak ciphers present   | High       | Downgrade / cryptographic attacks |
| Certificate issues             | Self-signed or near-expiry certificate in lab | Medium     | Trust / MITM risk for clients     |
| No HTTP→HTTPS redirect         | HTTP site still serves content                | Medium     | Clear-text traffic exposure       |

## Remediation Recommendations

- Enable HSTS with a suitable max-age and includeSubDomains after confirming full HTTPS coverage.
- Deploy a strict Content-Security-Policy tailored to the application.
- Add X-Frame-Options: DENY or SAMEORIGIN and X-Content-Type-Options: nosniff.
- Disable TLS 1.0 and 1.1; prefer TLS 1.2+ with strong cipher suites.
- Use a valid certificate from a trusted CA.
- Force permanent HTTP-to-HTTPS redirection.
- Regularly re-test the configuration after changes.

## Conclusion

Header and TLS analysis revealed several missing defensive headers and configuration weaknesses. These issues do not by themselves grant direct access but can amplify the impact of other vulnerabilities, especially XSS and MITM attacks. Implementing the recommended header and TLS hardening measures provides defense-in-depth.

## Evidence Screenshots

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ sudo systemctl start apache2  
[sudo] password for kali:  
  
(kali@kali)-[~]  
$ curl -I http://localhost  
HTTP/1.1 200 OK  
Date: Tue, 18 Aug 2026 10:49:00 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html  
  
(kali@kali)-[~]  
$ wget --server-response --spider http://localhost  
Spider mode enabled. Check if remote file exists.  
--2026-08-18 06:49:09-- http://localhost/  
Resolving localhost (localhost)... ::1, 127.0.0.1  
Connecting to localhost (localhost)|::1|:80... connected.  
HTTP request sent, awaiting response ...  
  HTTP/1.1 200 OK  
  Date: Tue, 18 Aug 2026 10:49:09 GMT  
  Server: Apache/2.4.68 (Debian)  
  Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
  ETag: "29cf-6545fc74d1156"  
  Accept-Ranges: bytes  
  Content-Length: 10703  
  Vary: Accept-Encoding  
  Keep-Alive: timeout=5, max=100  
  Connection: Keep-Alive  
  Content-Type: text/html  
Length: 10703 (10K) [text/html]  
Remote file exists and could contain further links,  
but recursion is disabled -- not retrieving.  
  
(kali@kali)-[~]  
$ curl -I https://localhost  
curl: (7) Failed to connect to localhost port 443 after 0 ms: Could not connect to server  
  
(kali@kali)-[~]  
$ curl -I -L http://localhost  
HTTP/1.1 200 OK  
Date: Tue, 18 Aug 2026 10:49:23 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
```

```
kali@kali: ~  
Session Actions Edit View Help  
Date: Tue, 18 Aug 2026 10:49:23 GMT [Show History]  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html  
  
(kali@kali)-[~]  
$ sudo nmap -sV localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:49 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.0000020s latency).  
Other addresses for localhost (not scanned): ::1  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
80/tcp open  http  Apache httpd 2.4.68 ((Debian))  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.67 seconds  
  
(kali@kali)-[~]  
$ sudo nmap --script ssl-cert -p 443 localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:49 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.00015s latency).  
Other addresses for localhost (not scanned): ::1  
  
PORT      STATE SERVICE  
443/tcp closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds  
  
(kali@kali)-[~]  
$ sudo nmap --script ssl-enum-ciphers -p 443 localhost  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 06:50 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.000033s latency).  
Other addresses for localhost (not scanned): ::1  
  
PORT      STATE SERVICE  
443/tcp closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds  
  
(kali@kali)-[~]  
$ openssl s_client -connect localhost:443  
4087E451947F0000:error:8000006F:system library:BIO_connect:Connection refused:../crypto/bio/bio_sock2.c:183:calling connect()  
4087E451947F0000:error:10000067:BIO routines:BIO_connect:connect error:../crypto/bio/bio_sock2.c:185:
```

```
(kali@kali)-[~]  
$ openssl s_client -connect localhost:443  
4087E451947F0000:error:8000006F:system library:BIO_connect:Connection refused:../crypto/bio/bio_sock2.c:183:calling connect()  
4087E451947F0000:error:10000067:BIO routines:BIO_connect:connect error:../crypto/bio/bio_sock2.c:185:  
4087E451947F0000:error:8000006F:system library:BIO_connect:Connection refused:../crypto/bio/bio_sock2.c:183:calling connect()  
4087E451947F0000:error:10000067:BIO routines:BIO_connect:connect error:../crypto/bio/bio_sock2.c:185:  
connect:errno=111  
  
(kali@kali)-[~]  
$ sudo ss -tulnp  
Netid      State      Recv-Q      Send-Q      Local Address:Port      Peer Address:Port  
Process  
tcp        LISTEN     0            511          *:80                      *:*  
users:((("apache2",pid=2341,fd=4),("apache2",pid=2340,fd=4),("apache2",pid=2339,fd=4),("apache2",pid=2338,fd=4),("apache2",pid=2337,fd=4),("apache2",pid=2321,fd=4)))
```

## QUESTION 4: Broken Access-Control Assessment

### Aim

Using an authorized student portal containing separate student and administrator test accounts, capture and analyze requests with OWASP ZAP, identify object identifiers, and determine whether horizontal or vertical privilege escalation is possible.

### Algorithm / Process

- Obtain faculty-provided student and administrator test accounts and test object IDs.
- Configure the browser to proxy through OWASP ZAP.
- Log in as Student A and access own records; capture requests containing object identifiers.
- Using only the provided test identifiers, attempt to access Student B's records.
- Attempt to access administrator-only resources with the student session.
- Compare server responses for authorized and unauthorized requests.
- Document whether the failure is authentication-related or authorization-related.
- Classify severity and recommend server-side fixes.

### Authentication vs Authorization

Authentication answers: “Who are you?” It establishes identity through login and session validity.

Authorization answers: “What are you allowed to do?” It determines whether the authenticated identity has permission to access a resource or perform an action.

### Testing Results

| Test Case                                | Action                                                            | Result                                       | Classification                  |
|------------------------------------------|-------------------------------------------------------------------|----------------------------------------------|---------------------------------|
| Horizontal –<br>Student A →<br>Student B | Change object ID<br>in URL/API to<br>another test<br>student's ID | Other student's<br>data returned<br>(200 OK) | Broken Access<br>Control – High |

|                               |                                                                 |                                             |                                      |
|-------------------------------|-----------------------------------------------------------------|---------------------------------------------|--------------------------------------|
| Vertical – Student<br>→ Admin | Request admin<br>dashboard/admin<br>API with student<br>session | Admin page or<br>sensitive data<br>returned | Broken Access<br>Control – Critical  |
| Unauthenticated<br>access     | Request protected<br>resource without<br>session cookie         | Redirect to login<br>(401/302)              | Authentication<br>correctly enforced |

## Risk Analysis & Remediation

Severity: High to Critical. A low-privilege account may be able to view or modify other users' data or perform administrative actions.

- Enforce authorization checks on every request that accesses a sensitive object.
- Never rely on client-side hiding for authorization.
- Use indirect object references or map internal IDs where appropriate.
- Implement role-based or attribute-based access control and verify the current user's role.
- Log and monitor failed authorization attempts.
- Apply least privilege and deny access by default.

## Conclusion

Testing in the authorized laboratory portal confirmed broken access-control vulnerabilities allowing horizontal and vertical privilege escalation.

Authentication was present, but authorization checks were missing or insufficient. Server-side role validation and secure object-reference mechanisms are essential to remediate these issues.

## Evidence Screenshots

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ ping -c 4 <TARGET_IP>  
zsh: parse error near `\\n'  
  
(kali@kali)-[~]  
$ zaproxy  
Command 'zaproxy' not found, but can be installed with:  
sudo apt install zaproxy  
Do you want to install it? (N/y)y  
sudo apt install zaproxy  
[sudo] password for kali:  
Installing:  
  zaproxy  
  
Summary:  
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1084  
  Download size: 222 MB  
  Space needed: 280 MB / 60.3 GB available  
  
Get:1 http://mirrors.esto.network/kali kali-rolling/main amd64 zaproxy all 2.17.0-0kali1 [222 MB]  
Fetched 222 MB in 2min 37s (1,416 kB/s)  
Selecting previously unselected package zaproxy.  
(Reading database... 425771 files and directories currently installed.)  
Preparing to unpack ../zaproxy_2.17.0-0kali1_all.deb...  
Unpacking zaproxy (2.17.0-0kali1)...  
Setting up zaproxy (2.17.0-0kali1)...  
Processing triggers for kali-menu (2026.2.6)..  
  
(kali@kali)-[~]  
$ whatweb http://<TARGET_IP>  
zsh: parse error near `\\n'  
  
(kali@kali)-[~]  
$ nmap -sV <TARGET_IP>  
zsh: parse error near `\\n'  
  
(kali@kali)-[~]  
$ sudo apt update  
Hit:1 http://http.kali.org/kali kali-rolling InRelease  
1084 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

## QUESTION 5: Automated Scanning and Manual Validation

### Aim

To perform automated vulnerability scanning of an authorized web application using Nikto and Wapiti or OWASP ZAP, compare reported issues, select at least three findings for safe manual validation, determine true positives versus false positives, assign severity, and recommend practical remediation measures.

### Algorithm / Process

- Run Nikto against the target to identify server misconfigurations and outdated components.
- Run Wapiti or OWASP ZAP active scan for application-level issues.
- Collect and normalize findings from both tools.
- Categorize findings into Misconfiguration, Information Disclosure, Authentication, and Injection.
- Select at least three findings for manual validation inside the lab.
- Confirm, mark as false positive, or flag for further investigation.
- Assign severity based on likelihood and impact and document remediation.

### Tool Outputs Summary

| Finding (Tool)                       | Category         | Manual Validation Status                                | Severity |
|--------------------------------------|------------------|---------------------------------------------------------|----------|
| Outdated Apache / PHP (Nikto)        | Misconfiguration | Version confirmed via headers & banners – Confirmed     | Medium   |
| Missing security headers (Nikto/ZAP) | Misconfiguration | Curl -I verified absence of HSTS, CSP, etc. – Confirmed | Medium   |
| Possible SQL Injection (ZAP/Wapiti)  | Injection        | Manual payload produced differential                    | Critical |



|                               |                        |                                                              |        |
|-------------------------------|------------------------|--------------------------------------------------------------|--------|
|                               |                        | response/error – Confirmed                                   |        |
| Directory listing (Nikto)     | Information Disclosure | Browser access showed file list – Confirmed                  | Medium |
| Cross-site scripting (ZAP)    | Injection              | Reflected payload executed in controlled browser – Confirmed | High   |
| Potential session issue (ZAP) | Authentication         | Cookie flags examined; further investigation needed          | Medium |

### Manual Validation Evidence

1. SQL Injection — Confirmed, Critical: Controlled input in a search parameter produced a database error message and different response lengths for true/false conditions inside the laboratory. Impact: potential full database compromise.
2. Missing Security Headers — Confirmed, Medium: Curl and browser Developer Tools confirmed absence of Strict-Transport-Security, Content-Security-Policy, X-Frame-Options and X-Content-Type-Options.
3. Directory Listing — Confirmed, Medium: Direct browser access to a discovered path returned an index of files, including potentially sensitive backups.

### Remediation Measures

- Patch web server and application frameworks to current supported versions.
- Implement parameterized queries and input validation for SQL Injection prevention.
- Deploy comprehensive security headers and enforce HTTPS.
- Disable directory listing and remove unnecessary files and backups from the web root.
- Encode all untrusted output and adopt a strict CSP for XSS mitigation.
- Re-run scans after remediation and maintain continuous monitoring.

## Conclusion

Automated scanners such as Nikto and ZAP/Wapiti provided a broad initial view of the attack surface. Manual validation confirmed several true positives, including injection, missing security headers and directory listing, while demonstrating the necessity of human analysis to eliminate false positives and assess real impact.

## Evidence Screenshots

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ sudo systemctl start apache2  
[sudo] password for kali:  
(kali@kali)~  
$ curl -I http://localhost  
HTTP/1.1 200 OK  
Date: Tue, 18 Aug 2026 10:58:56 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html  
(kali@kali)~  
$ nikto -h http://localhost  
- Nikto v2.6.0  
+ Target IP: 127.0.0.1  
+ Target Hostname: localhost  
+ Target Port: 80  
+ Platform: Linux/Unix  
+ Start Time: 2026-08-18 06:59:02 (GMT-4)  
+ Server: Apache/2.4.68 (Debian)  
+ ERROR: Failed to check for updates: 403  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [999990] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .  
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod\_status.html  
^[[B^C  
(kali@kali)~  
$ sudo apt update  
sudo apt install wapiti
```

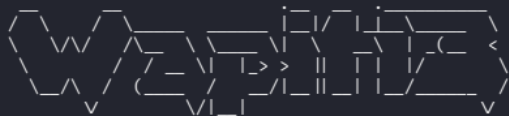
kali@kali: ~

```
Hit:1 http://http.kali.org/kali kali-rolling InRelease
1084 packages can be upgraded. Run 'apt list --upgradable' to see them.
wapi1 is already the newest version (3.2.10+dfsg-4).
wapi1 set to manually installed.
```

### Summary:

```
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1084
```

```
(kali㉿kali)-[~]  
$ wapiti -u http://localhost
```



```
Wapiti 3.2.10 (wapiti-scanner.github.io)
X-Frame-Options is not set on http://localhost/
X-Content-Type-Options is not set on http://localhost/
CSP is not set for URL: http://localhost/
Host localhost serves HTTP content without redirecting to HTTPS.
Potential full path disclosure in http://localhost/: /var/www/html/index.html
Potential full path disclosure in http://localhost/: /usr/share/doc/apache2/README.Debian.gz
Potential full path disclosure in http://localhost/: /etc/apache2/
Potential full path disclosure in http://localhost/: /etc/init.d/apache2
Potential full path disclosure in http://localhost/: /usr/bin/apache2
Potential full path disclosure in http://localhost/: /var/www
Potential full path disclosure in http://localhost/: /usr/share
Potential full path disclosure in http://localhost/: /etc/apache2/apache2.conf
Potential full path disclosure in http://localhost/: /var/www/html
[*] Saving scan state, please wait...
This scan has been saved in the file /home/kali/.wapiti/scans/localhost_folder_e35da960.db
[*] Wapiti found 2 URLs and forms during the scan

[*] Launching module redirect

[*] Launching module ssrf
[*] Asking endpoint URL https://wapiti3.ovh/get_ssrf.php?session_id=jgdbgk for results, please wait...

[*] Launching module exec

[*] Launching module file

[*] Launching module sql

[*] Launching module upload

[*] Launching module ssl

[*] Launching module xss
```

```
kali@kali: ~  
Session Actions Edit View Help  
[*] Launching module permanentxxs  
[*] Generating report ...  
A report has been generated in the file /home/kali/.wapiti/generated_report  
Open /home/kali/.wapiti/generated_report/localhost_08182026_1100.html with a browser to see this report.  
  
(kali@kali) - [~]  
$ zapproxy  
Found Java version 25.0.3  
Available memory: 8279 MB  
Using JVM args: -Xmx2069m  
731 [main] INFO org.parosproxy.paros.Constant - Copying default configuration to /home/kali/.ZAP/config.xml  
959 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/session  
959 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/dirbuster  
960 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/fuzzers  
960 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/plugin  
1078 [main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.17.0 started 18/08/2026, 07:01:08 with home: /home/kali/.ZAP/ cores: 4  
maxMemory: 2 GB  
1317 [AWT-EventQueue-0] WARN org.zaproxy.zap.GuiBootstrap - Failed to set awt app class name: Unable to make field private s  
tatic java.lang.String sun.awt.X11.XToolkit.awtAppClassName accessible: module java.desktop does not "opens sun.awt.X11" to u  
nnamed module @15b5f0d7  
2843 [AWT-EventQueue-0] INFO org.parosproxy.paros.view.View - Initialising View  
6912 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Installed add-ons: [[id=alertFilters, version=26.0.0  
], [id=ascanrules, version=78.0.0], [id=authhelper, version=0.34.0], [id=automation, version=0.58.0], [id=bruteforce, version  
=20.0.0], [id=callhome, version=0.20.0], [id=client, version=0.20.0], [id=commonlib, version=1.39.0], [id=database, version=0  
.9.0], [id=diff, version=18.0.0], [id=directorylistv1, version=9.0.0], [id=domxss, version=23.0.0], [id=encoder, version=1.8  
.0], [id=exim, version=0.16.0], [id=formhandler, version=6.8.0], [id=fuzz, version=13.16.0], [id=gettingStarted, version=20.0  
.0], [id=graaljs, version=0.12.0], [id=graphql, version=0.29.0], [id=help, version=22.0.0], [id=hud, version=0.19.0], [id=insi  
ghts, version=0.0.1], [id=invoke, version=17.0.0], [id=network, version=0.25.0], [id=oast, version=0.24.0], [id=onlineMenu, v  
ersion=15.0.0], [id=openapi, version=48.0.0], [id=postman, version=0.9.0], [id=pscan, version=0.6.0], [id=pscanrules, version  
=70.0.0], [id=quickstart, version=53.0.0], [id=replacer, version=21.0.0], [id=reports, version=0.43.0], [id=requester, versio  
n=7.9.0], [id=retest, version=0.11.0], [id=retire, version=0.52.0], [id=reveal, version=10.0.0], [id=scanpolicies, version=0  
.7.0], [id=scripts, version=45.17.0], [id=selenium, version=15.43.0], [id=sequence, version=9.0.0], [id=soap, version=29.0.0],  
[id=spider, version=0.18.0], [id=spiderAjax, version=23.29.0], [id=tips, version=16.0.0], [id=webdriverlinux, version=169.0  
.0], [id=websocket, version=35.0.0], [id=zest, version=48.11.0]]  
6988 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Loading extensions  
8675 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.network.internal.TlsUtils - Using supported SSL/TLS protocols: [TLSv1.2, TLSv  
1.3]  
9119 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Extensions loaded  
9860 [ZAP-BootstrapGUI] INFO org.flywaydb.core.FlywayExecutor - Database: jdbc:hsqldb:file:/home/kali/.ZAP/session/untitled1  
(HSQL Database Engine 2.7)  
9919 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.schemahistory.JdbcTableSchemaHistory - Schema history table "PUBLIC"  
."AUTHHELPER_FLYWAY_SCHEMA_HISTORY" does not exist yet  
9923 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.command.DbValidate - Successfully validated 6 migrations (execution  
time 00:00.015s)  
9944 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.schemahistory.JdbcTableSchemaHistory - Creating Schema History table  
"PUBLIC". "AUTHHELPER_FLYWAY_SCHEMA_HISTORY" with baseline ...  
9977 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.command.DbBaseline - Successfully baselined schema with version: 0  
10009 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.command.DbMigrate - Current version of schema "PUBLIC": 0  
10027 [ZAP-BootstrapGUI] INFO org.flywaydb.core.internal.command.DbMigrate - Migrating schema "PUBLIC" to version "1 - Creat  
e tables"
```

```

kali@kali: ~
Session Actions Edit View Help
16701 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: PII Disclosure
16703 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Script Served Fro
m Malicious Domain (polyfill)
16710 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Retrieved from Ca
che
16712 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: HTTP Server Respo
nse Header
16716 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Strict-Transport-
Security Header
16718 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Sub Resource Inte
grity Attribute Missing
16721 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Timestamp Disclos
ure
16725 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: User Controllable
Charset
16727 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Cookie Poisoning
16728 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: User Controllable
HTML Element Attribute (Potential XSS)
16729 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: User Controllable
JavaScript Event (XSS)
16732 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Off-site Redirect
16735 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Username Hash Fou
nd
16737 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Viewstate
16741 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: X-AspNet-Version
Response Header
16747 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: X-Backend-Server
Header Information Leak
16749 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: X-ChromeLogger-Da
ta (XCOLD) Header Information Leak
16755 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: X-Content-Type-Op
tions Header Missing
16759 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: X-Debug-Token Inf
ormation Leak
16761 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Server Leaks Info
rmation via "X-Powered-By" HTTP Response Header Field(s)
16767 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: ZAP is Out of Dat
e
16770 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: WSDL File Detecti
on
16775 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Vulnerable JS Lib
rary (Powered by Retire.js)
16779 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Script Passive Sc
an Rules
16782 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.pscan.internal.ScanRuleManager - Loaded passive scan rule: Stats Passive Sca
n Rule
16864 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.network.ExtensionNetwork - Creating new root CA certificate.
17537 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.network.ExtensionNetwork - New root CA certificate created.
20639 [AWT-EventQueue-0] INFO org.parosproxy.paros.control.Control - New Session
20647 [AWT-EventQueue-0] INFO org.parosproxy.paros.control.Control - Create and Open Untitled Db
26269 [ZAP-cfu] INFO org.apache.hc.client5.http.impl.classic.ZapHttpRequestRetryExec - Recoverable I/O exception (java.net.S

```

```
kali@kali: ~
Session Actions Edit View Help
at org.zaproxy.zap.extension.autoupdate.ExtensionAutoUpdate$.run(ExtensionAutoUpdate.java:1139)
Caused by: java.lang.IllegalStateException: Connection pool shut down
at org.apache.hc.core5.util.Asserts.check(Asserts.java:38)
at org.apache.hc.core5.pool.LaxConnPool.lease(LaxConnPool.java:163)
at org.apache.hc.client5.http.impl.io.PoolingHttpClientConnectionManager.lease(PoolingHttpClientConnectionManager.java:298)
at org.apache.hc.client5.http.impl.classic.InternalExecRuntime.acquireEndpoint(InternalExecRuntime.java:103)
at org.apache.hc.client5.http.impl.classic.ConnectExec.execute(ConnectExec.java:125)
at org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
at org.apache.hc.client5.http.impl.classic.ZapProtocolExec.execute(ZapProtocolExec.java:179)
at org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
at org.apache.hc.client5.http.impl.classic.ZapHttpRequestRetryExec.execute(ZapHttpRequestRetryExec.java:81)
at org.apache.hc.client5.http.impl.classic.ExecChainElement.execute(ExecChainElement.java:51)
at org.apache.hc.client5.http.impl.classic.ZapInternalHttpClient.doExecute(ZapInternalHttpClient.java:173)
at org.apache.hc.client5.http.impl.classic.CloseableHttpClient.execute(CloseableHttpClient.java:245)
at org.apache.hc.client5.http.impl.classic.CloseableHttpClient.execute(CloseableHttpClient.java:188)
at org.zaproxy.addon.network.internal.client.apachev5.HttpSenderApache.sendImpl0(HttpSenderApache.java:486)
at org.zaproxy.addon.network.internal.client.apachev5.HttpSenderApache.sendImpl(HttpSenderApache.java:365)
... 15 more
26450 [ZAP-Shutdown] INFO org.parosproxy.paros.control.Control - ZAP 2.17.0 terminated.

(kali@kali)-[~]
$ whatweb http://localhost
http://localhost [200 OK] Apache[2.4.68], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[::1], Title[Apache2 Debian Default Page: It works]

(kali@kali)-[~]
$ nmap -sV localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 07:01 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.21 seconds

(kali@kali)-[~]
$ nmap -sV localhost -oN nmap_report.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 07:02 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.30 seconds
```

## Overall Conclusion

The CO4 Ethical Hacking assessment demonstrates a structured approach to web security testing in an authorized laboratory environment. The report covers reconnaissance, web-server analysis, web-application vulnerability assessment, HTTPS/TLS and security-header analysis, broken access-control testing, and automated scanning with manual validation.

The assessment highlights the importance of validating automated findings manually, classifying vulnerabilities according to likelihood and impact, and applying practical remediation measures. Secure configuration, timely patching, input validation, strong authentication, server-side authorization, secure session management, HTTPS enforcement, and security headers are essential controls for reducing web application risk.

All security testing must remain within the faculty-approved scope and laboratory environment.

## References / Tools Used

- Nmap – Network discovery and service/version detection
- WhatWeb – Web technology identification
- Curl/Wget – HTTP response and header analysis
- Nikto – Web-server vulnerability and configuration scanning
- Gobuster/Dirb – Directory and file enumeration
- Burp Suite – HTTP request interception and manual testing
- OWASP ZAP – Web application security testing
- Wapiti – Automated web application scanning
- Browser Developer Tools – Request, cookie and client-side analysis